

Veilway 簡化版執行計畫

架構說明見〈Veilway2.md〉，原本的建置順序見〈Veilway三階段執行計畫.md〉。

狀態：草案，討論中（2026-10-10）。本文件是「Veilway 討論」session 的討論結果，尚未取代原三階段執行計畫，也尚未更新 CLAUDE.md 的已定案決策。要不要採用、用什麼方式採用，見文末「待定案事項」。

為什麼要簡化

原三階段計畫用到的 AWS 元件很多：CloudFront、WAF、S3 前台、ALB、ECS Fargate（API 與閘道兩個 service）、多可用區 RDS、ElastiCache、SQS、Cognito、PrivateLink、Network Firewall，再加上 CDK。對目前的人力來說，光是把基礎設施建起來、維護好，就會吃掉大部分時間。

不過隱道真正的價值只有兩件事：

1. 遮蔽 → 檢查 → 還原：外部模型只看得到代號。
2. 租戶隔離：A 租戶碰不到 B 租戶的資料。

這兩件事都寫在 C# 程式和 PostgreSQL 裡，和用不用 ECS、CloudFront、SQS 無關。簡化版把基礎設施縮成 ALB + 1 台 EC2（IIS）+ RDS PostgreSQL，核心價值保持不變。

原則

- 基礎設施越少越好：能用 PostgreSQL 或應用程式做到的，就不另外加 AWS 服務。
 - 核心規則不簡化：租戶隔離、對照表、檢查點 fail-closed 等規則照原設計做（見「不簡化的規則」）。
 - 🌱 程式碼可以升級：程式碼照套件邊界拆成專案，只用跨平台的 ASP.NET Core API。日後要搬到 ECS 或 Linux，只需要換部署方式，不必重寫程式。
 - 每個階段結束時，系統都要能完整運作。
-

架構



元件

層	元件	說明
DNS	Route 53	veilway.app 和 *.veilway.app 都用 Alias 記錄指向 ALB；每個租戶一個子網域
憑證	ACM 萬用憑證	一張憑證同時涵蓋 veilway.app 和 *.veilway.app，用 DNS 驗證，ACM 自動續約，IIS 不必管憑證 (ACM DNS 驗證)
分流	ALB	結束 HTTPS 後轉給 EC2；健康檢查打 /health。⚠️ ALB 必須選至少 2 個可用區的子網，即使後面只有 1 台 EC2 (ALB 可用區)
前台	IIS	SPA 靜態檔放在同一個 IIS 網站的 wwwroot，API 走 /api/*
後端	1 台 EC2 + IIS	ASP.NET Core 以 In-Process 模式掛在 IIS 下；App Pool 設為 AlwaysRunning、關閉閒置逾時，背景工作才不會被停掉 (IIS 進階設定)
資料庫	RDS PostgreSQL 單可用區	私有子網、加密、不公開存取；開啟自動備份；啟用 pgvector (給之後的 RAG)
Session	PostgreSQL	Identity 的 Cookie 登入，登入票證存在 PostgreSQL (ITicketStore)；登出時刪除該筆紀錄，舊 Cookie 立即失效
限流	記憶體 + PostgreSQL	每秒請求頻率用 ASP.NET Core 內建 RateLimiter (只有一台機器，放記憶體即可，Rate limiting)；AI 額度與計量寫進 PostgreSQL
身分	ASP.NET Core Identity	使用者表帶 tenant_id；一位使用者只屬於一個租戶
檔案	S3 (私有)	依租戶分 prefix (tenants/{tenant_id}/...)，EC2 以 IAM role 存取 (建議，待確認，見待定案事項 2)
非同步	本機背景工作	IHostedService + PostgreSQL 工作表，用 FOR UPDATE SKIP LOCKED 取工作 (PostgreSQL 鎖定子句)；也可以直接用 Hangfire 的 PostgreSQL 版本
AI	Claude Platform on AWS	EC2 的 IAM role 驗證；先不做 PrivateLink，走 HTTPS 對外連線
橫向服務	Secrets Manager、KMS、CloudWatch	DB 連線字串、對照表加密金鑰、日誌與告警 (EC2 裝 CloudWatch Agent)

網路

項目	做法
VPC	2 個可用區，各一個公有子網、一個私有子網
ALB	公有子網（2 個可用區）
EC2	建議放公有子網，security group 只允許 ALB 連入；EC2 要對外連線（Claude、Windows Update），放公有子網就不需要 NAT Gateway（待確認，見待定案事項 3）
RDS	私有子網，security group 只允許 EC2 連入
管理	⚠️ 不開放 RDP 到公網；用 SSM Session Manager／Fleet Manager 管理機器

和原架構的差異

項目	原架構	簡化版	失去什麼	什麼時候要補回來
邊緣	CloudFront + WAF	ALB 直接對外	CDN、WAF 防護	需要時 ALB 可以直接掛 WAF
前台	S3 + CloudFront	IIS	靜態檔快取	流量變大時
後端	ECS Fargate，正式環境至少 2 個容器	1 台 EC2 + IIS	高可用：機器掛掉或 Windows Update 重開機時，服務會中斷	有付費客戶、簽 SLA 時
閘道	獨立 ECS service（自己的 SG、IAM role）	同一個程式裡的模組	用網路強制「唯一出口」：只能靠程式紀律加架構測試	有要求嚴格、或要通過資安稽核的租戶時
模型連線	PrivateLink	HTTPS 對外	流量不經公網	同上
資料庫	RDS 多可用區	RDS 單可用區	可用區故障時自動切換	和後端高可用一起
快取	ElastiCache	PostgreSQL + 記憶體	多台機器共用 Session 與限流	後端超過 1 台時
身分	Cognito	ASP.NET Core Identity	內建的 MFA、密碼重設、Email 驗證（要自己接）	—
非同步	SQS + Worker	本機背景工作	獨立擴充 Worker、DLQ	長任務多到影響 API 時
IaC	CDK（C#），全面參數化	主控台手動建立 + 建置清單	一鍵重建、複製環境	要開第二個產品或 staging 環境時
環境	dev、staging、prod	本機開發 + 1 套 AWS 環境	上線前的預演環境	有正式客戶時

不簡化的規則

以下規則和原設計一致，簡化版照做：

規則	簡化版的做法
每張業務資料表帶 <code>tenant_id</code> 並啟用 RLS	EF Core 開連線時執行 <code>SET app.tenant_id</code> ；應用程式用的 DB 帳號不是資料表擁有者，也沒有 <code>BYPASSRLS</code> ；migration 用另一個帳號
一位使用者只屬於一個租戶	登入時核對「子網域對應的租戶」和「使用者的 <code>tenant_id</code> 」一致，不一致就拒絕
⚠️ Cookie 不跨租戶	Cookie 不設 <code>Domain=.veilway.app</code> ，讓每個租戶子網域的 Cookie 各自獨立
對照表預設每個對話一張並設 TTL；絕不跨租戶	存在 RDS，以 KMS 加密；背景工作定期清除過期的對照表
檢查點補遮後仍命中就攔下；故障一律 fail-closed	同〈Veilway2.md〉第 5 節
只有隱道能呼叫模型	只有 <code>Veilway.Gateway</code> 專案引用 Anthropic SDK；用架構測試（例如 <code>NetArchTest</code> ）檢查其他專案沒有引用，接進 CI
日誌不印原始 prompt	定期抽查 CloudWatch 日誌
對外說法	「平台在台灣，只有代號化後的內容出境」；代號化屬於假名化，不宜稱匿名化
區域、網域	AWS 台北 <code>ap-east-2</code> ； <code>veilway.app</code> ，租戶用 <code><租戶>.veilway.app</code> （ACM 憑證掛在 ALB，所以在台北區域申請即可）
🌱 套件邊界	<code>Veilway.MultiTenancy</code> 、 <code>Veilway.Gateway</code> 、 <code>Veilway.Files</code> 各自獨立專案，另有最小範例產品；底座不寫產品專屬邏輯

第一階段：骨架

範圍

類別	項目
網路	VPC（2 個可用區的公有、私有子網）；ALB、EC2、RDS 三個 security group
DNS 與憑證	Route 53 的 <code>veilway.app</code> 與 <code>*.veilway.app</code> → ALB；ACM 萬用憑證（DNS 驗證）
EC2	Windows Server + IIS + ASP.NET Core Hosting Bundle；App Pool 設為 AlwaysRunning；IAM role（S3、Secrets Manager、KMS、CloudWatch、SSM）；SSM Patch Manager 設定固定的更新時段
資料庫	RDS PostgreSQL 單可用區、加密、自動備份；啟用 pgvector；migration 工具（EF Core migrations）；應用程式帳號與 migration 帳號分開
專案結構	<code>Veilway.sln</code> ： <code>Veilway.MultiTenancy</code> 、 <code>Veilway.Gateway</code> （空殼）、 <code>Veilway.Files</code> （空殼）、範例產品（前台 + API）
身分	ASP.NET Core Identity；使用者帶 <code>tenant_id</code> ；Session 票證存 PostgreSQL；登入時核對子網域與租戶
租戶管理	租戶建立與子網域對應；方案與額度的資料結構（計量在第二階段接上）
資料表	租戶、使用者、角色、Session；每張表都帶 <code>tenant_id</code> 並啟用 RLS
限流	ASP.NET Core RateLimiter（依租戶、依使用者）
部署	建置成 zip 上傳到 S3，用 SSM Run Command 部署到 IIS（先寫成腳本，之後再接 GitHub Actions）
監控與備份	CloudWatch Agent 收 IIS 與應用程式日誌；ALB 5xx、EC2 狀態、RDS 儲存空間告警；EC2 用 AWS Backup 定期做 AMI 備份

類別	項目
建置清單	主控台上每個資源的設定值寫成清單（名稱以 <code>veilway</code> 開頭），作為之後重建或改寫成 CDK 的依據

不做

AI 功能、檔案上傳、背景工作。

驗收標準

- ☐ 使用者能從租戶子網域登入，前台呼叫 API 成功；用 A 租戶的帳號登入 B 租戶的子網域會被拒絕
- ☐ API 依登入者的租戶讀寫 RDS；A 租戶讀不到 B 租戶的資料（有自動化測試，包含直接用應用程式帳號下 SQL）
- ☐ RDS 不能從公網連到；EC2 只能從 ALB 連到，沒有開放 RDP
- ☐ 登出後，舊 Cookie 立即失效；超過限流門檻的請求回 429
- ☐ 重開 EC2 後，服務自動恢復（App Pool 自動啟動、ALB 健康檢查恢復正常）
- ☐ 依建置清單可以重建出同樣的環境

第二階段：隱道

範圍

類別	項目
模型接入	開通 Claude Platform on AWS（台北 workspace）；EC2 的 IAM role 加上呼叫權限；設定 <code>default_inference_geo</code> 、 <code>allowed_inference_geos</code>
隱道管線	<code>IChatClient</code> + <code>DelegatingChatClient</code> ：遮蔽 → 檢查點 → 送出 → 還原 → 計量，全部寫在 <code>Veilway.Gateway</code> ；業務 API 只透過公開介面呼叫
出口紀律	架構測試：只有 <code>Veilway.Gateway</code> 引用 Anthropic SDK；接進 CI
遮蔽設定化	個資類型、正規表示式、租戶字典、提示詞、檢查點政策都由設定提供
遮蔽器	正規表示式 + 租戶字典（管理介面與匯入）；NER 列為後段項目
檢查點	對照表原值比對、正規表示式重掃、字典比對；處理規則同〈 <code>Veilway2.md</code> 〉第 5 節；故障時 fail-closed
還原器	能容錯的代號比對；串流緩衝區
資料表	對話、訊息、對照表（每個對話一張、TTL、KMS 加密）、 <code>AI_REQUEST_LOG</code> （只存遮蔽後的內容與 <code>usage.inference_geo</code> ）、攔截紀錄
計量與額度	每次的 token 用量寫進 PostgreSQL；超過方案額度就拒絕
前台	對話介面（串流顯示）、對話列表、檢查點攔截的提示與確認畫面
測試集 v1	格式類個資 + 字典命中案例，接進 CI

後段項目

- 繁中 NER 與別名展開（CPU 執行；注意 EC2 的記憶體與 CPU 夠不夠）

- 測試集 v2：困難案例，加上遮蔽前後回答品質的比較
- Ollama 當開發替身，驗證隱道連接器只改 endpoint 就能切換

不做

Tool calling、RAG、檔案上傳。

驗收標準

- ☐ 使用者能在網頁上和 AI 多輪對話，回覆以串流顯示
- ☐ 從 `AI_REQUEST_LOG` 抽查，送出的內容找不到測試資料裡的個資
- ☐ 架構測試證明只有 `Veilway.Gateway` 能呼叫模型
- ☐ 測試集上，格式類個資召回率 99.9% 以上，字典類 100%
- ☐ 檢查點故障時，請求會被拒絕，不會放行
- ☐ 每個租戶的 token 用量能查詢；超過方案額度時會被擋下
- ☐ 日誌中找不到原始 prompt（抽查）

風險

- 推論在境外（`inference_geo` 只有 `global`、`us`）：上線前要完成跨境傳輸的揭露文字與合約條款
- 零資料保留（ZDR）要向 Anthropic 申請，審核時間要預留
- 模型可能不會原樣保留代號，還原器的容錯規則要用實際回覆來調整
- 只有一台 EC2：遮蔽（尤其 NER）和串流都在同一台機器上，要量測延遲與 CPU 用量

第三階段：檔案與背景工作

範圍

類別	項目
上傳	API 簽發 presigned URL，前台直接上傳到 S3（私有、SSE-KMS、依租戶分 prefix）；限制檔案大小與類型
背景工作	PostgreSQL 工作表（狀態、重試次數、錯誤訊息）； <code>IHostedService</code> 用 <code>FOR UPDATE SKIP LOCKED</code> 取工作；失敗超過次數就標成「失敗」並觸發告警（取代 DLQ）
文件處理	抽出文字（PDF、Office 檔）→ 遮蔽 → 存進 RDS；呼叫 AI 一樣經過 <code>Veilway.Gateway</code>
工作狀態	前台顯示處理進度（輪詢）
文件問答	「針對這份文件提問」；大型文件切段處理
生命週期	S3 lifecycle 規則；刪除對話或租戶時，連同檔案、對照表、相關紀錄一起清除
套件化	上傳、工作框架、抽文字與遮蔽寫在 <code>Veilway.Files</code>

可選項目

- RAG：pgvector + 租戶範圍的對照表；嵌入模型用平台內 CPU 模型
- Tool calling：參數還原 → 平台內執行 → 結果重新遮蔽

- 影像 OCR、錄音轉文字 (⚠ 很吃 CPU，可能要另外開一台 Worker EC2，或改回 SQS + Worker)

驗收標準

- ☐ 上傳 50 MB 的 PDF 後，API 立即回應，進度正確顯示，處理完成後可以對文件提問
- ☐ 處理失敗的工作會標成失敗並觸發告警，不會遺失；EC2 重開後，未完成的工作會繼續處理
- ☐ 送給模型的文件內容經過遮蔽 (抽查 AI_REQUEST_LOG)
- ☐ 刪除對話後，S3 檔案、對照表、相關紀錄都一併清除
- ☐ A 租戶拿不到 B 租戶的檔案 (presigned URL 限制在該租戶的 prefix，並有有效期限)

升級路徑：從簡化版到原架構

簡化版的程式碼照套件邊界拆分，日後可以逐項升級，不必一次全換。

觸發條件	升級項目
需要高可用 (付費客戶、SLA)	EC2 加到 2 台 (或改 ECS Fargate) + RDS 改多可用區；Session 與頻率限流已在 PostgreSQL，限流改成共用即可
需要強制「唯一出口」	Veilway.Gateway 拆成獨立服務 (第二台 EC2 或 ECS service)，給它自己的 SG 與 IAM role，再加 PrivateLink
長任務影響 API	背景工作搬到獨立 Worker，佇列可以留在 PostgreSQL 或換成 SQS
需要 WAF、CDN	ALB 掛 WAF；前台改 S3 + CloudFront
要開第二個產品或 staging	依建置清單把環境寫成 CDK (C#)

跨階段持續項目

項目	第一階段	第二階段	第三階段
測試集	—	v1 格式類 + 字典	加入文件案例
稽核	登入紀錄	AI 請求、攔截紀錄	檔案存取紀錄
監控	ALB、EC2、RDS 基本告警	遮蔽與攔截統計、模型延遲	工作佇列堆積、失敗工作
成本	預算告警	每個租戶的 token 計量與額度	儲存與處理量
安全檢查	跨租戶存取測試	出口架構測試、日誌抽查	檔案權限測試
維運	Windows Update 時段、AMI 與 RDS 備份	—	—

待定案事項

要採用簡化版，以下幾點需要在「Veilway 討論」session 決定：

1. 簡化版和原計畫的關係 (建議選 A) - A. 簡化版是先行版：先用簡化版做出能上線的系統，原三階段計畫保留為升級目標 (見「升級路徑」)。 - B. 簡化版取代原計畫。
2. 檔案放哪裡：建議放 S3。放在 EC2 磁碟上，機器壞掉時檔案也會跟著不見，備份也比較麻煩。

3. EC2 放哪個子網：建議放公有子網（security group 只允許 ALB），省下 NAT Gateway 的費用；放私有子網加 NAT 比較安全，但成本較高。
4. 為什麼選 IIS／Windows：Windows EC2 要另外付授權費（價差待確認）。如果團隊熟悉 IIS 就值得；如果不是，Linux + Kestrel 一樣能跑同一份程式。
5. 環境數量：只有一套 AWS 環境，加上本機開發，是否足夠。

定案後要配合修改的文件

文件	負責 session	要改的地方
CLAUDE.md	Veilway 討論	已定案決策表中的「系統元件」「闡道」「IaC」「對照表（ElastiCache 那句）」「建置順序」
Veilway2.md	Veilway 討論	第 1 節（元件）、第 6 節（出口管控）加上簡化版的說明或升級路徑
Veilway三階段執行計畫.md	Veilway 討論	標明和本文件的關係（升級目標或已被取代）
Veilway架構圖v2.html ／.pdf	Veilway 討論	加一張簡化版架構圖
Veilway第一階段操作手冊.md	第一階段	改動最大：CDK、ECS、CloudFront、Cognito、ElastiCache 改成 EC2 + IIS、ALB、Identity、PostgreSQL Session
Veilway第二階段操作手冊.md	第二階段	闡道從獨立 ECS service 改成同程式內的模組 + 架構測試；不做 PrivateLink
Veilway第三階段操作手冊.md	第三階段	SQS + Worker 改成 PostgreSQL 工作表 + 背景工作